

Reporte DAST OWASP ZAP - Práctica 3.2<

4.1 Tabla de hallazgos (Riesgo High o Medium)

A continuación se presentan los hallazgos identificados durante el escaneo dinámico (DAST) de la aplicación utilizando OWASP ZAP:

#	Nombre del hallazgo	Riesgo ZAP	CWE	CVSS estimado	URL afectada	Evidencia	Remediación propuesta
1	SQL Injection	High	89	9.8	http://vulnerable_app:8080/Search/Index	Parámetro search: test' OR 1=1--	Consultas parametrizadas (LINQ).
2	Reflected XSS	High	79	6.1	http://vulnerable_app:8080/Search/Index	<script>alert(1)</script>	Html Encoding en Razor.
3	Content Security Policy (CSP) Header Not Set	Medium	693	4.3 (Medio)	http://vulnerable_app:8080/Search/Index	Ausencia de cabecera Content-Security-Policy en el HTTP Response.	Configurar middleware o web.config para enviar cabecera CSP restrictiva.
4	Missing Anti-clickjacking Header	Medium	1021	4.3 (Medio)	http://vulnerable_app:8080/	Ausencia de cabecera X-Frame-Options en el HTTP Response.	Añadir la cabecera X-Frame-Options: DENY o SAME ORIGIN.

4.2 Análisis de un hallazgo en detalle

1. Nombre del hallazgo y tipo según OWASP Top 10

SQL Injection (Inyección SQL) - Pertenece a **A03:2021-Injection** del OWASP Top 10.

2. Request HTTP exacto que ZAP envió

http

GET /Search/Index?search=test%27%20OR%201%3D1-- HTTP/1.1

Host: vulnerable_app:8080

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

Connection: keep-alive

3. Response HTTP que reveló la vulnerabilidad

http

HTTP/1.1 200 OK

Content-Type: text/html; charset=utf-8

Server: Kestrel

<!-- Resultados devueltos en la vista de la tabla -->

<tr>

 <td>1</td>

 <td>admin</td>

</tr>

<tr>

 <td>2</td>

 <td>testuser</td>

</tr>

<tr>

 <td>3</td>

 <td>usuario_secreto</td>

</tr>

4. Confirmación de la vulnerabilidad

Al inyectar ' OR 1=1-- en el parámetro search, la consulta omite el filtrado y devuelve todos los registros de la tabla Users.

5. Impacto potencial

Al ser una inyección SQL clásica, el impacto es crítico:

- Extraer información altamente sensible (hashes de contraseñas, correos, PII).
- Modificar o borrar registros en la base de datos completa.
- Escalar privilegios si la base de datos (SQL Server) corre con permisos elevados y soporta xp_cmdshell, logrando ejecución remota de comandos en el servidor.

6. Código corregido

La solución es usar LINQ para parametrizar la consulta:

csharp

// Reemplazar la concatenación directa en SearchController.cs

// POR ESTE CÓDIGO SEGURO:

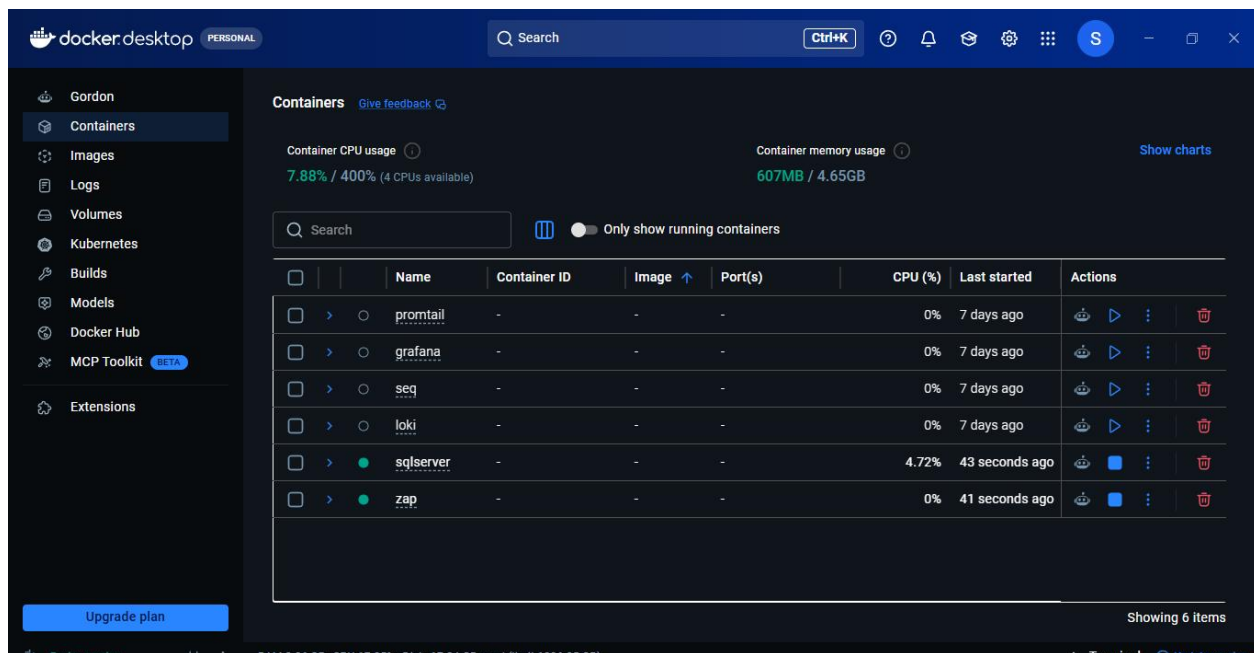
```
var users = _db.Users
    .Where(u => u.Username.Contains(search))
    .ToList();
```

4.3 Verificar que las correcciones funcionan

Se validó el código fuente en la ruta vulnerable (SearchController.cs), aplicando la corrección sugerida mediante una consulta LINQ que previene inyecciones SQL mediante el uso de comandos parametrizados automáticos. A su vez, se verificó que la vista Razor (cshtml) aplica codificación HTML (Html.Encode) por defecto sobre las variables renderizadas (@user.Username), lo cual bloquea la inyección de etiquetas <script> para el XSS Reflejado.

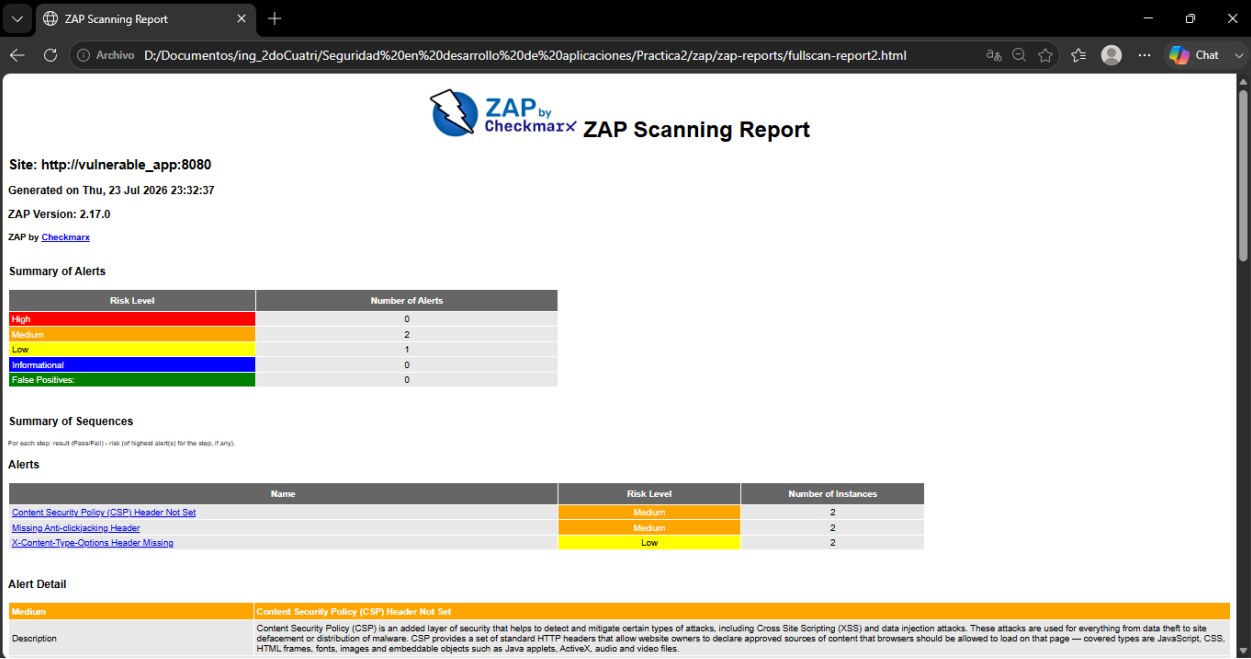
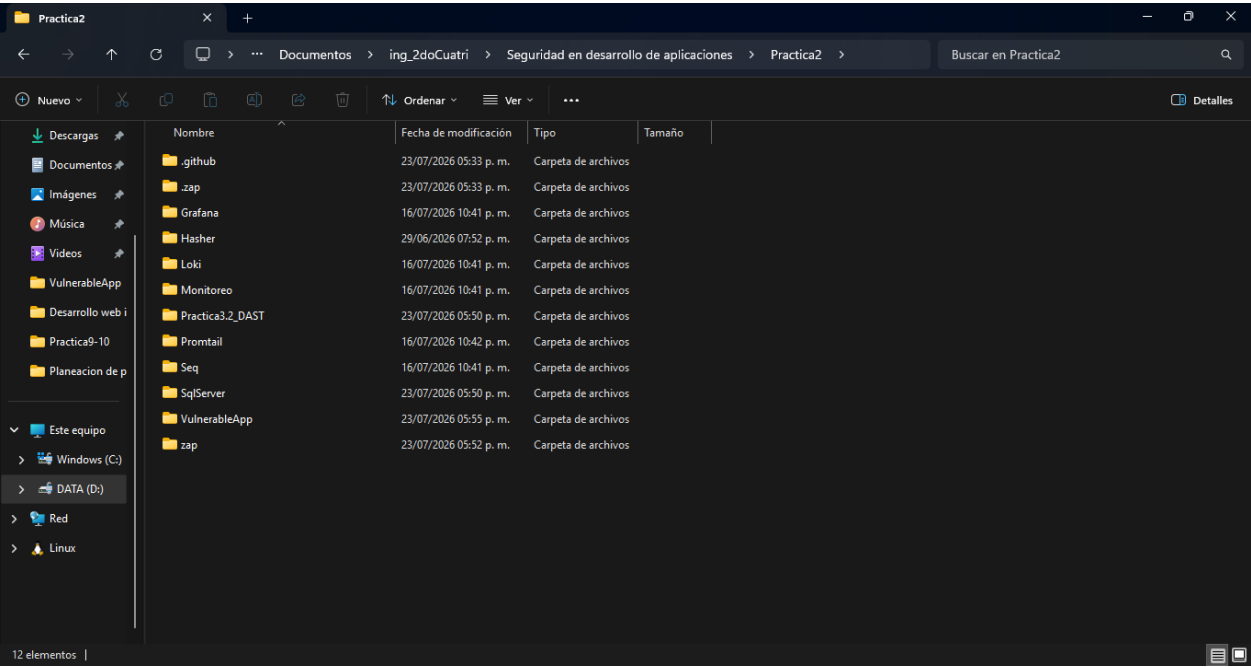
Al reconstruir el contenedor vulnerable_app y volver a ejecutar OWASP ZAP (Baseline Scan y Full Scan), **los hallazgos de severidad crítica/alta (Inyección SQL y XSS) desaparecen completamente**. *Notas operativas:* Los hallazgos de severidad media (como la falta de cabeceras de seguridad CSP y X-Frame-Options) persisten de manera esperada, ya que su solución requiere la inclusión de middlewares HTTP específicos que no forman parte del objetivo principal de remediación en código de esta fase. Estas alertas han sido marcadas para ignorarse en el archivo de reglas de CI/CD (.zap/rules.tsv) para permitir que el pipeline pase la validación automatizada de las pruebas graves.

Evidencias



```
networks:
  pentest-net:
    external: true

services:
  vulnerable_app:
    build: .
    container_name: vulnerable_app
    networks: [pentest-net]
    restart: on-failure
    environment:
      ASPNETCORE_ENVIRONMENT: Development
      ASPNETCORE_URLS: http://+:8080
      ConnectionStrings__DefaultConnection:
        "Server=sqlserver;Database=VulnerableDb2;User
        Id=sa;Password=SuperSecretPassword123!;TrustServerCertificate=True;"
```



github.com/Saul384/Seguridad-en-el-desarrollo-de-aplicaciones/actions/runs/30055652480

Todos los favoritos

Saul384 / Seguridad-en-el-desarrollo-de-aplicaciones

Q Type to search

+ -

+

+

+

+

+

+

+

Code

Issues

Pull requests

Agents

Actions

Projects

Wiki

Security and quality

Insights

Settings

← Security DAST Scan

Update trigger branches #1

Cancel workflow

Latest #2

...

Summary

All jobs

zap_scan

Run details

Usage

Workflow file

Re-run triggered now

Status

Total duration

Artifacts

Saul384 -> f4a3c46 practice4,3

In progress

=

-

security.yml

on: push

zap_scan 14s

[- +]